Glossário Prático de DevSecOps

Projeto Final DevSecOps Clube Aurora (Turma 1746)

> Consulte as definições e termos técnicos abaixo para fundamentar a elaboração do seu projeto e relatórios em qualquer uma das três trilhas (**Nível 1 Teórica Guiada, Nível 2 Misto e Nível 3 Técnica**).

[SEGURANÇA] Metodologias & Conceitos Fundamentais

- **Shift-Left Security:** A prática de mover a segurança para as fases iniciais do ciclo de desenvolvimento de software (na máquina do desenvolvedor, no linter e no primeiro commit), em vez de esperar a aplicação estar pronta ou implantada em produção para realizar testes de penetração.
- **Tríade CIA (Confidencialidade, Integridade, Disponibilidade):**
- **Confidencialidade:** Garantir que dados sensíveis (como credenciais, senhas e informações VIP de clientes) sejam acessíveis exclusivamente por identidades autorizadas.
- **Integridade:** Assegurar que os dados, parâmetros e códigos não sofram adulteração, injeção ou corrupção não autorizada.
- **Disponibilidade:** Garantir que o sistema, serviços e bancos de dados permaneçam operacionais e responsivos aos usuários legítimos.
- **Modelagem de Ameaças STRIDE:**
- **S**poofing (Falsificação de Identidade / Assumir a conta de outro usuário).
- **T**ampering (Adulteração de Dados ou Código em trânsito ou repouso).
- **R**epudiation (Repúdio / Incapacidade de auditar e comprovar a autoria de uma ação).
- **I**nformation Disclosure (Vazamento de Informação / Acesso a dados sigilosos).
- **D**enial of Service (Negação de Serviço / Indisponibilidade por sobrecarga ou travamento).
- **E**levation of Privilege (Elevação de Privilégio / Usuário comum obtendo permissões administrativas).
- **Princípio do Menor Privilégio (Least Privilege):** Regra fundamental segundo a qual cada usuário, processo, contêiner ou serviço deve possuir estritamente as permissões mínimas essenciais para realizar sua atividade de negócio, e nenhuma autorização excedente.
- **Segregação de Funções (SoD - Separation of Duties):** Princípio de governança que impede que uma única pessoa concentre poderes excessivos que permitam cometer e encobrir fraudes (ex: um operador não deve ser capaz de criar e aprovar transações financeiras sem dupla custódia).

[ANÁLISE] Tipos de Análise e Ferramentas

- **SAST (Static Application Security Testing):** Análise estática que inspeciona o código-fonte sem executá-lo, procurando vulnerabilidades lógicas, injeções de comandos e padrões inseguros (exemplo: Semgrep).
- **SCA (Software Composition Analysis):** Varredura automatizada de dependências e bibliotecas externas declaradas no projeto para identificar falhas públicas conhecidas (CVEs) e violações de licenças de software (exemplo: Trivy fs).

- **DAST (Dynamic Application Security Testing):** Análise dinâmica que avalia a aplicação em tempo de execução através de testes de caixa-preta via rede HTTP, simulando ataques externos para detectar cabeçalhos faltantes, falhas de sessão e erros de configuração (exemplo: OWASP ZAP).
- **Container Hardening:** Conjunto de práticas defensivas para blindar contêineres e imagens Docker contra ataques e escapes para o hospedeiro (ex: compilação multi-stage, uso de usuário não-root, imagens base minimalistas e instruções de healthcheck).
- **Misconfiguration (Má Configuração):** Falhas decorrentes de parâmetros frouxos ou perigosos em arquivos de infraestrutura como código (IaC), tais como executar contêineres em modo `privileged`, montar o socket do Docker (`/var/run/docker.sock`) ou expor portas de debug.
- **SBOM (Software Bill of Materials):** O "inventário formal de componentes" digital em padrão aberto (como SPDX ou CycloneDX) que lista todas as bibliotecas, módulos de terceiros e versões contidas no artefato compilado.

Engenharia de CI/CD e Git

- **CVE (Common Vulnerabilities and Exposures):** Dicionário público e padronizado que atribui um identificador único internacional (ex: `CVE-2024-1135`) a falhas de segurança conhecidas em componentes de software.
- **SARIF (Static Analysis Results Interchange Format):** Formato padrão baseado em JSON adotado pela indústria (OASIS) para intercambiar e consolidar resultados de múltiplos scanners de segurança (Semgrep, Trivy, Hadolint) na interface do GitHub Code Scanning.
- **Exit Code (Código de Saída):** Número inteiro retornado por um comando ou processo ao finalizar sua execução no sistema operacional. No Linux e PowerShell, o código `0` significa sucesso; qualquer código diferente de zero (como `exit 1`) sinaliza erro e aborta a esteira no GitHub Actions.
- **Quality Gate:** Barreira automatizada na esteira de CI/CD que bloqueia o avanço da entrega de software caso determinadas métricas pré-estabelecidas sejam violadas (ex: reprovar o build se houver qualquer vulnerabilidade com severidade `HIGH` ou `CRITICAL`).
- **Fork:** Cópia independente de um repositório Git sob a sua própria conta, permitindo que você experimente e realize modificações livremente sem afetar a árvore principal original.
- **Pull Request (PR):** Mecanismo de colaboração onde um desenvolvedor propõe a integração de alterações feitas em uma branch para a branch principal (`main`), servindo como palco central para revisão por pares e disparo de pipelines de validação.
- **Branch Protection Rules (Regras de Proteção de Branch):** Políticas configuradas no repositório remoto para impedir commits diretos na branch principal (`main`), exigindo aprovação via Pull Request e validação de testes automatizados com status verde antes do merge.
- **Falso Positivo (False Positive):** Situação em que uma ferramenta de segurança sinaliza incorretamente um trecho de código ou biblioteca como vulnerável, quando na realidade o contexto de uso do sistema impossibilita a exploração da falha.
- **Aceite de Risco & Exceção Formal (Risk Acceptance):** Procedimento de governança onde a equipe de engenharia e segurança avalia formalmente um achado que não possui correção imediata do mantenedor e documenta o aceite temporário do risco (ex: através de um arquivo `.trivyignore` estruturado com justificativa e data de expiração).